



GOVERNANCE DOCUMENT

Cybersecurity and Information Security Policy

International Society of Equity Analysts

DOCUMENT VERSION

1.2

DATE APPROVED

1 July 2025

LAST UPDATED

1 July 2026

ADMINISTERED BY

AI Technology and
Innovation Committee

Document Control

DOCUMENT OWNER	AI Technology and Innovation Committee
APPROVAL AUTHORITY	Governing Council
ADMINISTERED BY	AI Technology and Innovation Committee
DATE APPROVED	1 July 2025
LAST UPDATED	1 July 2026
DOCUMENT VERSION	1.2
NEXT REVIEW DATE	1 July 2027
RELATED DOCUMENTS	Privacy Policy Risk Management Policy Document Retention Policy Whistleblower Policy Complaints Policy Disciplinary Policy Membership Policy Membership Regulations Member Admission Framework Code of Ethics and Standards of Professional Conduct

This document forms part of the official governance framework of the International Society of Equity Analysts (ISEA) and should be read together with the related documents listed above.

Contents

1. Purpose	4
2. Scope and Application	4
3. Information Security Governance	4
4. Information Security Principles	5
5. Information Classification and Handling.....	6
6. Access Control.....	7
7. Passwords and Authentication.....	7
8. Member and Applicant Data	8
9. Financial Information and Payment Security.....	9
10. Endpoint, Network and Device Security	9
11. Email, Phishing, Social Engineering and Malware	10
12. Cloud Services and Third-Party Platforms.....	11
13. Backups, Business Continuity and Recovery.....	11
14. Cybersecurity Incident Management	12
15. Security Responsibilities	13
16. Security Awareness and Training.....	14
17. Security Monitoring, Logging and Assurance	14
18. Data Retention, Secure Disposal and Records	15
19. Exceptions, Non-Compliance and Enforcement.....	15
20. Review and Continuous Improvement	16
21. Effective Date	16

1. Purpose

The International Society of Equity Analysts (ISEA) is committed to protecting the confidentiality, integrity and availability of information entrusted to it and to maintaining secure and resilient technology services in support of its global professional, membership, education, assessment, governance and administrative activities.

This Cybersecurity and Information Security Policy ("Policy") establishes the principles, minimum requirements, governance arrangements and security responsibilities that apply to ISEA information, information systems, technology resources and the persons and organisations that access or manage them.

ISEA recognises that its operations depend upon the secure handling of member information, applicant and assessment records, professional and research information, financial information, governance records, communications, credentials and information processed through cloud and third-party platforms. A failure to protect those assets may affect members, applicants, employees, volunteers, officers, committees, service providers, partners and the reputation and continuity of ISEA.

The purpose of this Policy is to establish a consistent information-security framework capable of operating across jurisdictions and organisational environments while remaining proportionate to the nature and sensitivity of the information involved. The Policy supports secure professional operations, protects stakeholder trust, reduces cyber risk and provides a clear basis for prevention, detection, response, recovery and continuous improvement.

2. Scope and Application

This Policy applies to all ISEA information assets, technology systems and information-processing activities, whether operated directly by ISEA or provided through a third party. It applies irrespective of location, device, network, storage medium or technology platform.

The Policy applies to the Governing Council, Secretary-General, Executive Secretariat, officers, employees, committee members, Members, Fellows, Student Members, Associate Members, volunteers, contractors, consultants, assessors, examination personnel, service providers and other persons who are granted access to ISEA information or systems, to the extent relevant to their role.

The Policy applies to information created, received, collected, accessed, used, disclosed, transmitted, stored, archived or destroyed by or on behalf of ISEA, including information held in physical and electronic form.

Where an ISEA function is delegated to a service provider or other third party, the delegation does not transfer ISEA's responsibility to maintain appropriate oversight of information-security risks. Third parties shall be subject to security requirements proportionate to the services provided and the information they process.

The Policy shall be interpreted consistently with the ISEA Charter, applicable Committee Charters, the Privacy Policy, Ethics Policy, Conflict of Interest Policy, Document Retention Policy, Risk Management Policy, Whistleblower Policy, Complaints Policy, Disciplinary Policy, Membership Policy, Membership Regulations, Member Admission Framework, Code of Ethics and Standards of Professional Conduct and other applicable ISEA requirements.

Where a specific ISEA policy or applicable legal or regulatory requirement establishes a more stringent protection requirement, the more stringent requirement shall apply to the extent of the inconsistency.

3. Information Security Governance

ISEA shall maintain an information-security governance framework appropriate to its size, international activities, technology environment and risk profile. Information security is an organisational responsibility and shall not be treated solely as a technical function.

3.1 Governing Council Oversight

The Governing Council has overall oversight responsibility for ISEA's governance and risk framework and shall receive appropriate information concerning material cybersecurity risks, significant incidents, material control weaknesses and remediation priorities. The Governing Council may require periodic reporting on security posture, material third-party risks, resilience arrangements and significant changes to ISEA's technology environment.

3.2 Executive Accountability

The Secretary-General and Executive Secretariat are responsible for implementing approved governance requirements and ensuring that appropriate operational arrangements, resources and accountability mechanisms are established. They shall ensure that material security issues are escalated through established governance channels and that security considerations are incorporated into significant operational and technology decisions.

3.3 Security Coordination

ISEA shall designate an appropriate person, function or external specialist to coordinate information-security activities. The designated security function may be performed internally, externally or through a combination of resources, provided that responsibility and escalation authority remain clear.

The designated security function shall maintain appropriate security guidance, coordinate incident response, support risk assessments, monitor material control issues, advise on third-party services and report material matters to the Executive Secretariat and, where appropriate, the Governing Council.

3.4 Risk-Based Approach

Information-security risks shall be considered as part of ISEA's broader Risk Management Policy and risk-management framework. Material technology risks, cyber threats, control deficiencies and security incidents shall be documented and managed according to their likelihood, potential impact, criticality and urgency.

3.5 Separation of Duties

ISEA shall maintain appropriate separation between security oversight, system administration, financial approval and other incompatible duties where practicable, particularly for privileged access, payment administration and high-risk changes. Where staffing or operational limitations prevent complete segregation, compensating controls such as independent review, logging or secondary approval should be applied.

4. Information Security Principles

ISEA shall apply the following principles to the protection of information and information systems.

- Confidentiality — information shall be accessible only to persons or systems authorised to receive it.
- Integrity — information shall be protected against unauthorised alteration, destruction, manipulation or corruption.
- Availability — information and systems shall be available when required for legitimate ISEA activities, subject to planned maintenance and reasonable resilience measures.
- Least privilege — access shall be limited to the minimum information, systems and functions required for an authorised purpose.
- Need to know — access to sensitive information shall be based on a legitimate business, governance, professional or administrative requirement.
- Security by design — security and privacy considerations should be incorporated into new systems, processes and services before deployment.
- Defence in depth — ISEA should use multiple complementary controls rather than relying on a single security measure.

- Accountability — access and significant security activities should be attributable to an identifiable user, administrator or service account.
- Risk-based protection — security controls shall be proportionate to the sensitivity, criticality and risk associated with the information or system.
- Continuous improvement — ISEA shall learn from incidents, testing, emerging threats, changes in technology and its operating environment.

4.1 Proportionality

ISEA does not require identical controls for every system. A public-facing informational service and a membership or financial system may require different safeguards. The applicable level of protection shall reflect the information held, the consequences of compromise, the system's role in ISEA operations and the capabilities of the service provider.

4.2 Secure-by-Default Behaviour

Where practical, systems should be configured so that access, sharing and publication are restricted by default and are expanded only for legitimate purposes. Users should not be required to understand technical security settings merely to avoid exposing sensitive information.

5. Information Classification and Handling

ISEA shall classify information according to its sensitivity, business importance, legal or contractual obligations and the potential impact of unauthorised disclosure, alteration, loss or unavailability.

5.1 Minimum Classification Levels

At a minimum, information should be treated as Public, Internal, Confidential or Restricted. ISEA may establish more detailed classification standards or handling procedures where required.

Public information is information that ISEA has intentionally authorised for public release, such as approved public website content, public statements and other information formally designated for public dissemination.

Internal information is information intended for ISEA personnel and authorised participants in ISEA activities that would not ordinarily be appropriate for public disclosure but whose compromise would generally have limited impact.

Confidential information includes member records, applicant information, internal governance papers, committee materials, contracts, credentials, non-public operational information and other information where unauthorised access could materially affect an individual or ISEA.

Restricted information includes highly sensitive personal, financial, security, assessment, authentication, investigation or other information where unauthorised disclosure, alteration or loss could cause significant harm, legal exposure, financial loss or serious reputational damage.

5.2 Handling Requirements

Users shall handle information in accordance with its classification. Confidential and Restricted information shall not be transmitted through unapproved channels, stored on unapproved personal services or disclosed to persons who lack an appropriate need to know.

Information classification shall be considered when selecting storage locations, sharing methods, encryption, access permissions, retention arrangements, disposal methods and third-party services.

5.3 Sharing and External Disclosure

Before sharing Confidential or Restricted information externally, the sender should confirm the recipient, purpose, authority, minimum necessary information and appropriate transmission method. Where appropriate, secure file-sharing, access-controlled links, encryption or equivalent safeguards should be used.

Public disclosure of information shall be limited to information approved for publication. Internal working documents, committee papers, member lists, assessment content and other non-public

information shall not be published merely because a user believes disclosure would be convenient or beneficial.

6. Access Control

ISEA shall implement access controls designed to prevent unauthorised access to information and systems. Access shall be granted based on role, legitimate purpose, need to know and least privilege.

6.1 Account Provisioning

User accounts shall be individually assigned wherever practicable. Shared accounts should be avoided and may be used only where a documented operational requirement exists and appropriate compensating controls are implemented.

Access shall be approved by an authorised person responsible for the relevant system or information. Privileged access shall require additional approval and shall be limited to persons who require it for defined responsibilities.

6.2 Joiner, Mover and Leaver Controls

ISEA shall maintain processes for joiners, movers and leavers. Access shall be established when required, adjusted promptly when responsibilities change and revoked without undue delay when a person's access is no longer authorised.

Where a person changes role, committee, project or employment status, access shall be reassessed rather than automatically retained. Departing personnel shall return ISEA property and information and shall not retain copies of Confidential or Restricted information except where authorised by ISEA.

6.3 Privileged Access

Privileged accounts shall be separated from ordinary user accounts where practicable. Administrative credentials shall not be used for routine email, web browsing or general-purpose activity.

Privileged activity should be logged where technically available. Administrators shall not disable security controls, alter logs or bypass approved security processes except where necessary for authorised maintenance or incident response.

6.4 Periodic Access Reviews

Access reviews shall be performed periodically for systems containing sensitive member, financial, assessment, governance or administrative information. Reviews shall consider inactive accounts, excessive privileges, departed users, role changes and unusual access arrangements.

6.5 Remote and External Access

Remote access to ISEA systems shall use approved secure mechanisms and appropriate authentication. Unauthorised remote-access tools, personal remote-control software or bypass mechanisms shall not be used to access ISEA systems.

6.6 Assessment and Examination Access

Access to assessment, examination and professional-designation systems shall be restricted to authorised personnel and shall incorporate appropriate controls to protect assessment integrity, applicant confidentiality and examination materials.

7. Passwords and Authentication

Passwords and authentication credentials are security controls and shall be protected from disclosure, reuse, theft and unauthorised use.

7.1 Password Requirements

Users shall use unique passwords for ISEA accounts and shall not reuse ISEA passwords on unrelated external services. Passwords shall not be shared with colleagues, contractors or support personnel.

Passwords shall be sufficiently long and resistant to common guessing and automated attacks. Where supported, ISEA shall encourage or require passphrases and password-manager use rather than insecure password reuse or predictable patterns.

7.2 Multi-Factor Authentication

Multi-factor authentication ("MFA") shall be required for administrative access and should be enabled for systems containing Confidential or Restricted information, remote access, financial administration, cloud administration, email and other high-risk services where the capability is available.

Authentication factors shall be protected. Users shall not approve unexpected authentication prompts, disclose one-time codes, forward authentication messages or register unknown authentication devices.

7.3 Credential Compromise

Where authentication credentials are suspected to have been compromised, the user shall immediately report the suspected compromise and follow instructions to reset credentials, revoke sessions, replace authentication factors or undertake other containment measures.

7.4 Service Accounts and Secrets

Service accounts, application credentials, API keys and other non-human authentication secrets shall be stored securely, restricted to the minimum required permissions and rotated or replaced when compromise is suspected or when required by the relevant system's risk profile.

7.5 High-Risk Authentication

ISEA shall use stronger authentication and additional verification for high-risk activities such as changes to payment instructions, privileged account changes, large financial transactions, security-control changes and access to highly sensitive records.

8. Member and Applicant Data

ISEA shall protect member and applicant information throughout its lifecycle. This includes information relating to Student Members, Associate Members, Members, Fellows, applicants, referees, assessment participants and other persons interacting with ISEA.

8.1 Types of Protected Information

Member and applicant information may include identity and contact details, membership status, professional history, qualifications, references, application information, assessment materials, declarations, payment information and communications. Access shall be limited to persons with a legitimate role-based need.

8.2 Privacy and Lawful Handling

ISEA shall take reasonable steps to ensure that personal information is collected, used, stored, transferred and disclosed only for authorised purposes and in accordance with the Privacy Policy and applicable privacy and data-protection requirements.

8.3 Membership Systems

Systems used for membership administration shall implement appropriate account security, access control, auditability and data-protection measures. Bulk exports of member data shall be restricted and should be encrypted where appropriate.

Member information shall not be downloaded, copied or transferred to personal devices or unapproved services except where expressly authorised for a legitimate ISEA purpose and protected appropriately.

8.4 Assessment and Admission Records

Assessment and admission records require particular protection because they may contain professional histories, qualifications, references, research submissions, examination materials and integrity-related information. Such information shall be shared only with authorised assessment or administrative personnel.

Research submissions and examination materials shall be protected from unauthorised copying, distribution, alteration or access. Where external assessors or service providers are used, access shall be limited to the material necessary for the assessment function and subject to appropriate confidentiality and security requirements.

8.5 Remote Assessments

Where ISEA conducts remote examination, videoconferencing, identity-verification or monitoring activities, appropriate safeguards shall be applied to protect participant information and preserve assessment integrity. Technology used for assessment shall be reviewed for access, recording, retention and disclosure implications before material deployment.

9. Financial Information and Payment Security

ISEA shall protect financial information and financial systems against unauthorised access, fraud, alteration, theft and disruption.

9.1 Financial Information

Financial information may include payment-card information, bank details, invoices, membership fees, refunds, payroll information, supplier payment details, financial reports, budgets, banking credentials and transaction records.

9.2 Payment Processing

Payment-card information should be processed through appropriately secured payment providers wherever practicable. ISEA personnel should not store complete payment-card information in ordinary email, spreadsheets, local files or general-purpose document repositories unless a specific approved process requires it.

9.3 Payment Verification

Changes to supplier bank details, payment instructions or other high-risk financial information shall be subject to independent verification using a trusted communication channel. Email instructions alone shall not be treated as sufficient verification for high-risk changes.

9.4 Financial Access

Access to banking, accounting and payment systems shall be restricted to authorised personnel. Privileged financial access shall be reviewed periodically and removed promptly when no longer required.

Financial records shall be protected against unauthorised modification. Where practicable, important financial transactions and changes to payment instructions should be traceable to an authorised user.

9.5 Financial Fraud and Business-Email Compromise

Suspected payment fraud, business-email compromise, unauthorised bank-account changes or suspicious financial transactions shall be escalated immediately. ISEA shall act promptly to contain the risk and, where appropriate, contact relevant financial institutions, service providers, insurers, law-enforcement authorities or regulators.

10. Endpoint, Network and Device Security

ISEA devices used to access ISEA information shall be maintained in a secure condition appropriate to their risk. This includes organisation-managed computers, mobile devices, tablets and other endpoints used for ISEA activities.

10.1 Secure Configuration

Devices shall use supported operating systems and applications and shall receive security updates within a timeframe appropriate to the risk. Unsupported or materially insecure software shall not be used for sensitive ISEA activities unless an approved exception exists.

Security controls should include device encryption where available and appropriate, screen locking, anti-malware or endpoint protection, firewall controls and secure configuration.

10.2 Physical Security

Users shall lock or otherwise secure devices when unattended and shall not leave Confidential or Restricted information exposed in public or shared environments. Meetings, committee sessions and assessment activities shall be conducted with reasonable regard to screen visibility, document exposure and unauthorised recording.

10.3 Mobile and Portable Media

Portable devices containing sensitive ISEA information shall be protected against loss or theft. Where practicable, remote-wipe or equivalent recovery controls should be enabled for mobile devices used to access sensitive information.

ISEA information shall not be transferred to removable media unless there is a legitimate need and the media is appropriately secured. Unapproved USB devices or removable storage shall not be connected to ISEA systems where doing so creates an avoidable security risk.

10.4 Network Security

Public or unsecured networks shall be treated as higher-risk environments. Users shall use approved secure connections when accessing ISEA systems remotely and shall avoid conducting sensitive activities over untrusted networks where adequate protection is unavailable.

ISEA shall use appropriate network protections for systems under its control, including secure administration, access restrictions and separation of sensitive services where practical.

11. Email, Phishing, Social Engineering and Malware

ISEA recognises phishing, business-email compromise, social engineering and malware as significant sources of cyber risk. Users shall remain alert to messages that seek credentials, financial information, confidential documents, payment changes, authentication codes or urgent actions.

11.1 Phishing and Social Engineering

Users shall verify unexpected requests for money, sensitive information, password resets, account changes, confidential files or unusual access. Requests involving urgency, secrecy, authority pressure or unusual payment instructions shall be treated as potential indicators of fraud.

Links and attachments from unexpected or suspicious messages shall not be opened. Users shall not enter ISEA credentials into websites reached through suspicious links or disclose authentication codes in response to unsolicited messages.

11.2 Email Security Controls

ISEA shall use appropriate technical controls to reduce email-based threats, including spam filtering, malicious-link or attachment controls and authentication or anti-spoofing measures where supported by the email platform.

11.3 Malware Prevention

Malware may include viruses, ransomware, spyware, credential stealers, malicious macros, trojans and other software intended to compromise systems or information. Users shall not install unapproved software, browser extensions or executables on ISEA devices.

11.4 Reporting and Containment

If a user believes they have clicked a malicious link, opened a suspicious attachment, entered credentials into a fraudulent site, installed suspicious software or otherwise triggered a security concern, they shall report it immediately. They should not delay reporting out of concern about blame or embarrassment.

ISEA shall promote a security culture in which prompt reporting is encouraged. Early reporting may materially reduce the impact of a cyber incident.

11.5 Ransomware

Suspected ransomware shall be treated as a high-priority incident. Affected devices should be isolated from networks where safe to do so, and users should not attempt to negotiate, delete evidence or independently restore systems without direction from the incident-response lead or authorised technical personnel.

12. Cloud Services and Third-Party Platforms

ISEA relies, or may rely, on cloud services and third-party platforms for membership management, communications, collaboration, payments, website hosting, events, learning, assessment, document storage and other activities. These services shall be selected and managed with appropriate security oversight.

12.1 Due Diligence

Before adopting a material cloud or third-party service that will process Confidential or Restricted information, ISEA should consider the provider's security capabilities, authentication options, access controls, data handling, incident notification arrangements, service resilience, backup arrangements, subcontractors and contractual protections.

12.2 Contractual and Operational Controls

Contracts or service arrangements should address confidentiality, data protection, security responsibilities, incident notification, access to information, retention and deletion, service continuity and termination arrangements where appropriate to the risk.

Third-party access shall be limited to the services and information necessary for the contracted purpose. Provider accounts shall use individual identities where practicable, and privileged vendor access should be controlled, monitored and removed when no longer required.

12.3 Cloud Configuration

Third-party platforms shall not be assumed to be secure merely because they are widely used or commercially reputable. ISEA remains responsible for configuring available security controls appropriately and for managing its own user access, permissions and information-handling practices.

Sharing settings, public links, administrator roles, external collaboration settings and data exports should be reviewed periodically for material services. Default settings should not be relied upon where they permit broader access than required.

12.4 Third-Party Inventory and Exit

ISEA shall maintain an inventory or register of material third-party services supporting critical or sensitive functions. The register should identify the service, owner, purpose, information processed and key security considerations.

When a third-party service is no longer required, ISEA shall take reasonable steps to terminate access, recover or delete information where appropriate, revoke credentials and confirm the disposition of sensitive information in accordance with applicable contractual and retention requirements.

13. Backups, Business Continuity and Recovery

ISEA shall maintain backup and recovery arrangements proportionate to the importance and sensitivity of its information and systems. The objective is to reduce the impact of accidental deletion, hardware failure, malicious activity, ransomware, service disruption and other events.

13.1 Backup Requirements

Critical information and systems shall be backed up using reliable processes. Backup scope, frequency and retention shall be determined according to business importance, recovery requirements, data-change rates and risk.

Backups containing Confidential or Restricted information shall be protected against unauthorised access. Where appropriate, backups should be encrypted and access should be separated from ordinary user permissions.

13.2 Recovery Resilience

ISEA should maintain resilience against ransomware and destructive attacks by ensuring that at least some recovery information is protected from routine alteration or deletion, where technically and operationally practicable.

13.3 Testing

Backup processes shall be monitored for failures. Material backup failures shall be investigated and corrected rather than allowed to persist unnoticed.

Recovery procedures shall be tested periodically for critical systems. Testing should confirm that information can be restored, that recovery procedures are understood and that dependencies on cloud providers, credentials, administrators or third parties are adequately considered.

13.4 Business Continuity

Business continuity and disaster recovery arrangements shall be coordinated with ISEA's broader risk-management and operational continuity processes. Recovery priorities should reflect the impact on members, applicants, governance, financial operations, assessment activities and professional programs.

Where critical services depend on a single cloud or technology provider, ISEA should consider reasonable contingency arrangements, alternative communication channels, data portability and manual workarounds appropriate to the risk.

14. Cybersecurity Incident Management

A cybersecurity incident is any actual or suspected event that may compromise the confidentiality, integrity or availability of ISEA information or systems, including unauthorised access, malware infection, phishing compromise, credential theft, data loss, ransomware, service disruption, fraud or accidental disclosure.

14.1 Reporting

All persons covered by this Policy are responsible for reporting suspected or actual incidents promptly through the designated ISEA reporting channel. A person who reports an incident in good faith shall not be discouraged from reporting because the cause may have involved an honest mistake.

14.2 Incident Response Lifecycle

Incident response shall ordinarily follow the principles of identification, containment, eradication, recovery and lessons learned, with communications and evidence preservation occurring throughout the process as appropriate.

Initial response shall focus on limiting harm. Depending on the circumstances, this may include disabling compromised accounts, isolating affected devices, revoking sessions or credentials, blocking malicious traffic, suspending suspicious transactions, restricting access to affected information or engaging specialist support.

14.3 Assessment and Classification

ISEA shall assess the nature, scope, affected systems, affected information, likely consequences and legal or contractual implications of an incident. Incidents involving member data, financial information, authentication credentials, assessment materials or material operational disruption shall receive appropriate priority.

Incidents may be categorised according to severity, taking account of the number and sensitivity of affected records, the duration of disruption, the possibility of ongoing compromise, financial impact, reputational impact and any applicable reporting obligations.

14.4 Evidence and Investigation

ISEA shall maintain appropriate incident records, including material actions taken, decisions, evidence, notifications, recovery activities and lessons learned. Records shall be handled confidentially and retained in accordance with applicable requirements.

Users shall not intentionally delete, modify or conceal potentially relevant evidence. Technical investigation should be undertaken by authorised personnel or qualified specialists where the nature of the incident warrants specialist expertise.

14.5 Notifications and Communications

Where required or appropriate, ISEA may notify affected individuals, service providers, insurers, regulators, law-enforcement authorities or other stakeholders. Notification decisions shall consider applicable legal, regulatory, contractual and professional obligations.

Incident communications shall be coordinated through authorised persons. Employees, volunteers, Members and other persons shall not make public statements concerning a significant cybersecurity incident on behalf of ISEA unless authorised to do so.

14.6 Recovery and Lessons Learned

Following a significant incident, ISEA shall conduct a post-incident review proportionate to the event. The review should identify root causes, control weaknesses, response effectiveness and corrective actions, and should assign responsibility and target dates for material remediation.

Where an incident identifies a systemic weakness, ISEA should consider whether the weakness affects other systems, third-party providers, committees or processes and should implement broader corrective measures where appropriate.

15. Security Responsibilities

Information security is a shared responsibility. The following responsibilities establish minimum accountability while allowing ISEA to allocate detailed operational duties through procedures, Committee Charters, employment arrangements or service contracts.

15.1 Governing Council and Governance Bodies

Governance bodies and the Governing Council shall provide oversight of material cybersecurity risks and ensure that information security is treated as part of ISEA's governance and risk framework.

15.2 Secretary-General and Executive Secretariat

The Secretary-General and Executive Secretariat shall ensure that appropriate operational arrangements, resources, policies and escalation mechanisms are in place and shall oversee implementation of this Policy.

15.3 Information Security Function

The designated information-security function shall coordinate security standards, risk assessments, incident response, security awareness, control reviews and security improvement activities, and shall provide appropriate reporting to management and governance bodies.

15.4 System and Service Owners

System and service owners shall understand the information and processes supported by their systems, approve appropriate access, maintain secure configurations, manage service risks and address identified weaknesses.

15.5 Managers, Officers and Committee Chairs

Managers and committee chairs shall ensure that persons under their responsibility receive appropriate access only for legitimate purposes and understand the security requirements relevant to their functions.

15.6 Users, Members and Volunteers

Users shall protect credentials, use approved systems, comply with information-handling requirements, remain alert to phishing and social engineering, report incidents promptly and complete required security training. Members and volunteers who receive ISEA information shall protect it and use it only for authorised purposes.

15.7 Contractors and Third Parties

Contractors and third-party service providers shall comply with contractual security requirements and shall promptly report security incidents affecting ISEA information or services.

15.8 Finance Personnel

Finance personnel shall apply appropriate controls to payment, banking and financial systems and shall independently verify high-risk payment changes.

15.9 Cooperation

All persons shall cooperate with reasonable security reviews, investigations and remediation activities, subject to applicable confidentiality, privacy and procedural-fairness requirements.

16. Security Awareness and Training

ISEA shall maintain security-awareness activities appropriate to the roles and risks of its stakeholders. Training should address practical behaviours rather than rely solely on technical concepts.

16.1 Core Awareness Topics

Security awareness should cover passwords and MFA, phishing, suspicious attachments and links, secure handling of member and financial information, use of cloud services, device security, remote working, incident reporting, social engineering and responsible use of technology and artificial intelligence.

16.2 Role-Based Training

Persons with privileged, financial, assessment, membership-administration or other high-risk responsibilities should receive additional role-specific guidance appropriate to their duties.

16.3 Exercises and Testing

ISEA may use simulated phishing, awareness exercises, briefings, guidance materials or other appropriate methods to reinforce secure behaviours. Such activities should be proportionate and should be used primarily for education and risk reduction.

16.4 Completion and Accountability

Failure to complete mandatory security training may result in restriction of access where appropriate to the risk and in accordance with applicable ISEA procedures.

17. Security Monitoring, Logging and Assurance

ISEA shall use monitoring and logging appropriate to the sensitivity and criticality of its systems. The objective is to support detection of unauthorised activity, investigation of incidents, operational assurance and accountability.

17.1 Logging

Where technically available and proportionate, security-relevant logs should record authentication events, privileged actions, material configuration changes, security alerts and other events necessary to investigate suspicious activity.

17.2 Protection of Logs

Logs containing personal or sensitive information shall themselves be protected against unauthorised access or alteration and retained only for as long as reasonably required under ISEA's Document Retention Policy and applicable requirements.

17.3 Security Testing

ISEA shall periodically assess the effectiveness of its security controls. Assurance activities may include access reviews, configuration reviews, vulnerability assessments, penetration testing, supplier reviews, backup testing, incident exercises or other appropriate checks.

17.4 Vulnerability Management

Material security weaknesses shall be recorded, prioritised and remediated according to risk. Critical or actively exploited vulnerabilities should receive expedited attention. Where immediate remediation is not possible, compensating controls and a documented remediation plan should be considered.

17.5 Privacy and Proportionality

Security monitoring shall be conducted consistently with privacy, employment, contractual and other applicable obligations. Monitoring shall have a legitimate security or operational purpose and shall be proportionate to that purpose.

18. Data Retention, Secure Disposal and Records

Information-security requirements apply throughout the information lifecycle, including creation, collection, use, sharing, storage, archiving and disposal.

18.1 Retention

ISEA shall retain information in accordance with its Document Retention Policy, applicable legal and regulatory requirements, contractual obligations and legitimate operational needs.

18.2 Secure Disposal

When information is no longer required, it shall be securely deleted, destroyed or otherwise disposed of using methods appropriate to its sensitivity and storage medium.

Electronic media containing Confidential or Restricted information shall be securely sanitised or destroyed before disposal, reuse or transfer where practicable.

Paper records containing sensitive information shall be disposed of through secure destruction methods rather than ordinary waste.

18.3 Preservation Requirements

Where information is subject to a legal hold, investigation, complaint, disciplinary matter, audit or other requirement that prevents disposal, it shall not be destroyed until the applicable hold or requirement has been released.

18.4 Copies and Local Storage

Users should avoid creating unnecessary copies of sensitive information. Temporary downloads, local copies and exported reports should be deleted or securely stored when no longer needed and should not become unmanaged shadow repositories.

19. Exceptions, Non-Compliance and Enforcement

ISEA recognises that exceptional operational circumstances may require temporary deviation from a security control. Exceptions shall be documented, risk-assessed, approved by an authorised person and subject to an appropriate expiry or review date.

19.1 Compensating Controls

Exceptions shall not be used to avoid implementing reasonable controls where an appropriate alternative is available. Compensating controls should be considered where a standard control cannot be implemented.

19.2 Non-Compliance

Actual or suspected non-compliance with this Policy may be reviewed by ISEA. Depending on the circumstances, ISEA may require remediation, restrict or revoke access, require additional training, refer the matter under the Disciplinary Policy, terminate a service relationship or take other appropriate action.

19.3 Immediate Protective Measures

Nothing in this Policy limits ISEA's ability to take immediate protective action where necessary to protect information, systems, members, applicants, finances or the integrity of ISEA activities.

19.4 Procedural Fairness

Investigations and enforcement shall be conducted consistently with applicable ISEA policies, including the Ethics Policy, Disciplinary Policy, Complaints Policy and Whistleblower Policy, and shall have regard to confidentiality, procedural fairness and applicable legal requirements.

20. Review and Continuous Improvement

ISEA shall periodically review this Policy and its supporting information-security framework to ensure that they remain appropriate for ISEA's international operations, technology environment and risk profile.

20.1 Review Factors

The review shall have regard to developments in cyber threats, technology, cloud services, artificial intelligence, remote working, authentication methods, privacy and data-protection requirements, professional practices, third-party dependencies, incident experience and the evolving needs of ISEA's members and stakeholders.

20.2 Continuous Improvement

ISEA shall seek to improve its security maturity through lessons learned from incidents, exercises, assurance activities, control reviews, changes in technology and emerging threats. Material recommendations should be documented and assigned to an accountable owner.

20.3 Approval of Amendments

The designated information-security function or responsible officer shall recommend amendments where appropriate, subject to the governance and approval requirements applicable to ISEA policies. Material changes should be communicated to relevant stakeholders.

20.4 Review Frequency

The Policy should be reviewed at least annually and sooner where a material change in ISEA's operating environment, technology architecture, legal or regulatory obligations, threat environment or organisational structure warrants earlier review.

21. Effective Date

This Cybersecurity and Information Security Policy takes effect on the date approved by the Governing Council.

The Policy shall remain in force until amended or replaced in accordance with ISEA's governance requirements.